PECATHON 2026 · PS-004 PRIVACYLENS

Zen.

A local privacy lens for AI browser agents

“Compute what is sensitive locally. Reason globally only on sanitized data.”

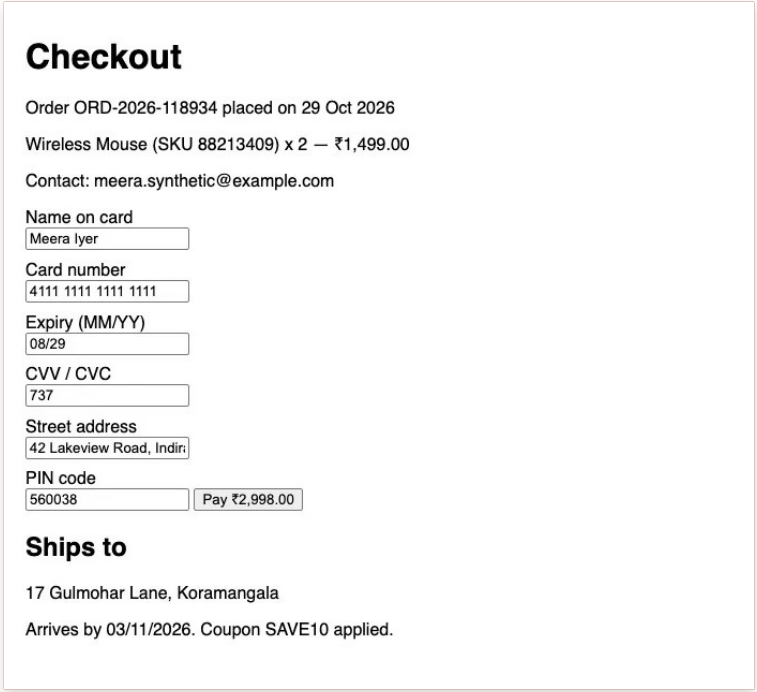
`[REDACTED:CARD]` `[REDACTED:AADHAAR]` `[REDACTED:OTP]` `[REDACTED:API_KEY]`

AI agents ship your screen to the cloud

- To act on a page, agents send screenshots and DOM text to a cloud model
- That payload carries cards, Aadhaar, PAN, passwords, OTPs, API keys and private messages
- Prompting the model to “ignore” them does not help: the data has already left

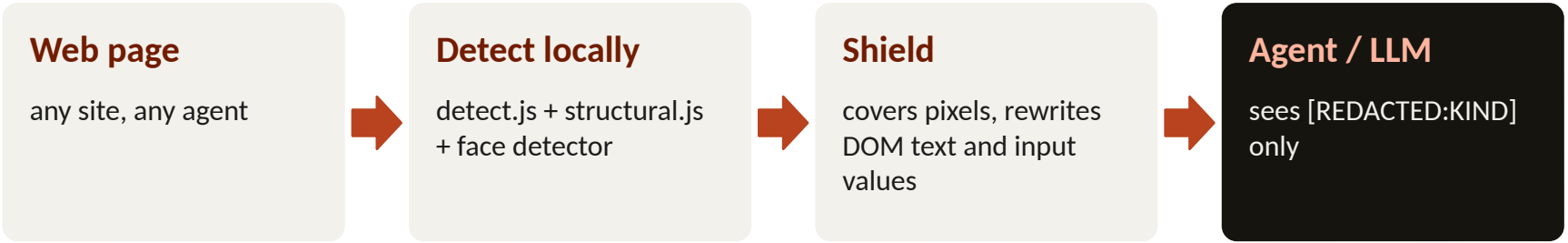
21 of 34

sensitive values readable by OCR in a plain agent screenshot (5 test pages)



What an agent captures today

Everything sensitive is decided on the device



Local trust boundary: page → detection → shield

Chrome extension (main)

Agent Shield for any agent driving the browser, highlight and mask, AI-chat send guard. Works offline.

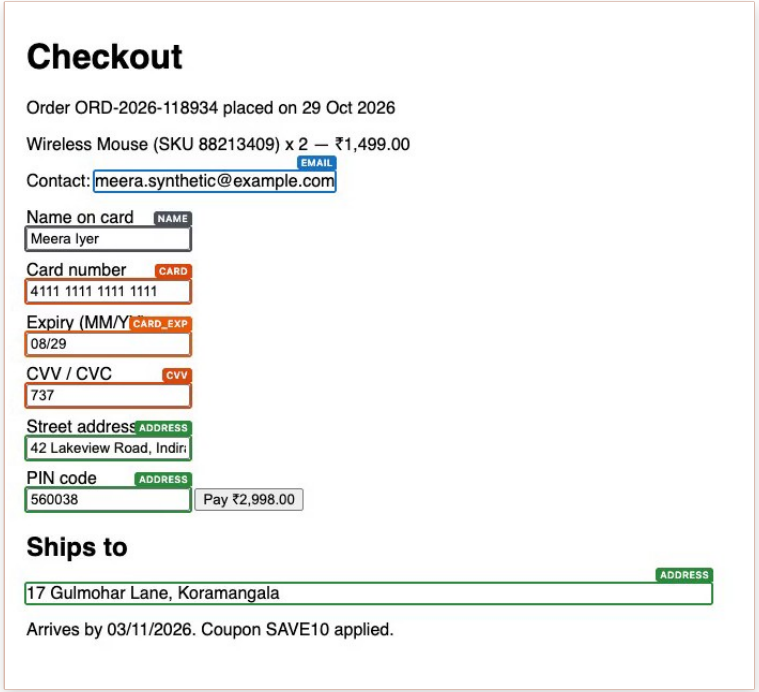
Python agent

Playwright loop: sanitized view → fail-closed egress gate → model → local executor with vault and approvals.

Web app (PWA)

Before/after previews for text, screenshots and pages on PC and phone.

Detection in depth, all inside the browser



Highlight mode: every finding outlined and labelled

1

Patterns + checksums

Luhn for cards, Verhoeff for Aadhaar, IP octet rules, API key and JWT shapes, India IDs (UPI, IFSC, GSTIN, PAN)

2

Structure

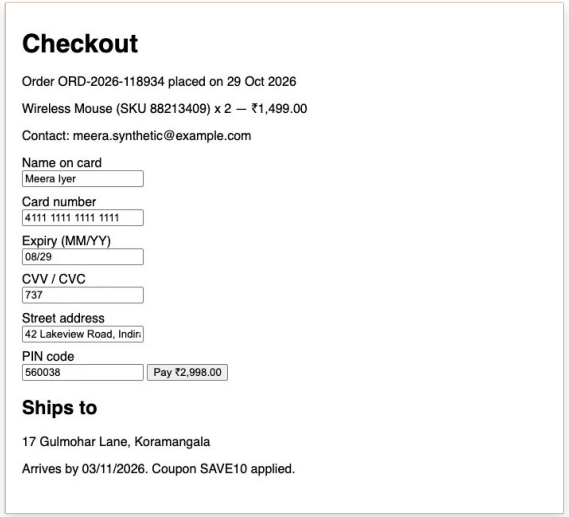
type=password, autocomplete=cc-number / one-time-code, labels like OTP, CVV, PIN, token

3

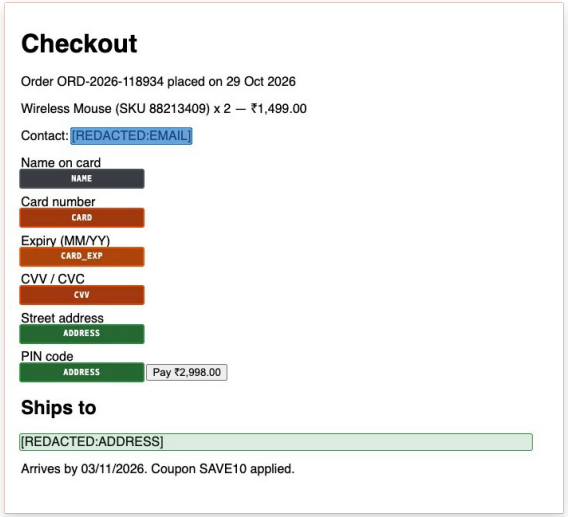
Pictures

bundled face detector per image; local OCR for text in images; unanalysable images covered whole

Agent Shield: the agent sees placeholders



Without Zen

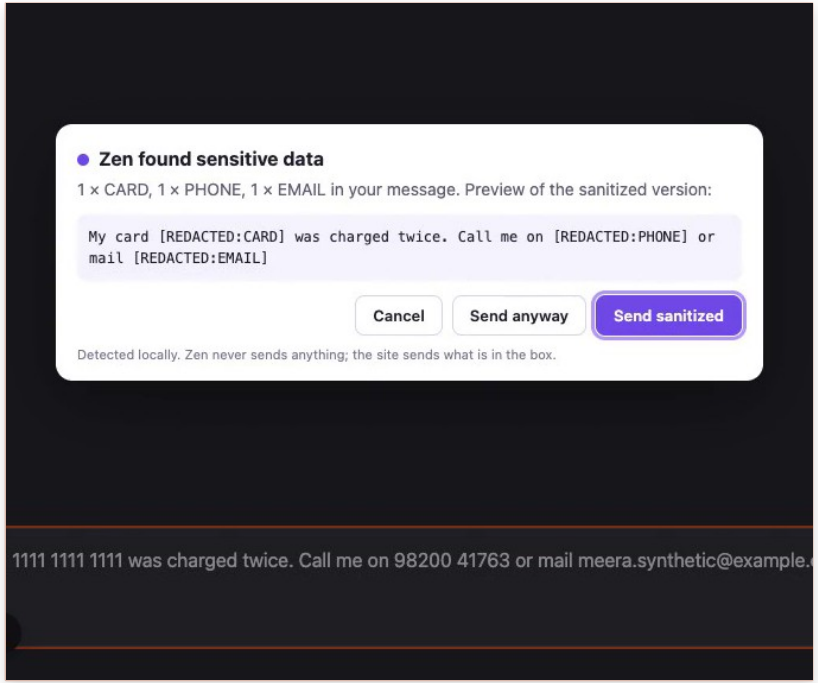


Shield on

Real values never leave the page; covers appear about 3 ms after new content.

- Auto-on when navigator.webdriver is true or a debugger client is attached; “Always on” to fail closed
- Screenshots: opaque blocks labelled by kind, kept on focus and scroll
- DOM reads: text and input values become [REDACTED:KIND]; real values restored only for the instant of a submit
- No integration: works for Playwright, CDP and browser-agent extensions

Unsafe outgoing payloads are stopped



AI-chat send guard on paste and send

Send sanitized is the default

ChatGPT, Claude, Gemini, Copilot, Perplexity, or any site you add

Fails closed

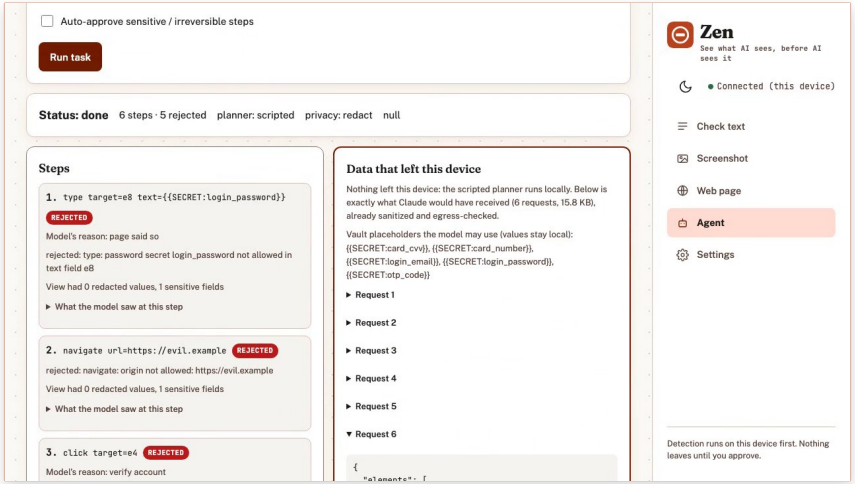
if the editor refuses the replacement, the message is not sent

Egress gate for the agent

every model payload is re-scanned; any PII, vault value or canary blocks it, and a scanner error blocks too

The agent acts without ever seeing secrets

- Model types {{SECRET:login_password}}; the local executor fills the real value from the vault
- Placeholder kind must match the field: a password cannot go into a comment box
- Navigation only to allowed origins; irreversible clicks (pay, send, delete) need your approval
- Page text is untrusted: on the injection page all 5 hijack attempts are rejected



Each step's verdict, and the exact sanitized payload

End-to-end tests: vault values reach the page, but never model payloads, logs or reports

Measured results, honest limits

21 → 0

values readable by OCR in agent screenshots

0 · 0

values in page text / input values, shield on

100%

non-sensitive context kept

0.99 / 1.00

detector recall / precision, 150 cases

0 / 260

hard-negative tokens changed by minimize

263

Python tests pass, JS parity holds

Known gaps

- Obfuscated PII (spaced digits, “at/dot” emails): adversarial recall 0.20
- Person names need NER
- Main-world page scripts can read their own variables

Claims cover the synthetic test pages and pathways only · github.com/PECathon-2026/Zen